



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



Review intake draft: CVE-2026-41108 Windows DNS Client Elevation of Privilege Vulnerability

Vulnerability Report

Classification	TLP:CLEAR
Published	2026-06-10
Version	1.0
Author	Lost Boys Cyber
Report Type	Vulnerability Report

TLP:CLEAR | Lost Boys Cyber | Review intake draft: CVE-2026-41108 Windows DNS Client Elevation of Privilege Vulnerability - Vulnerability Report

Published: 2026-06-10 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Intelligence Requirement
3. Source Review and Confidence
4. Key Findings
5. Threat Context
6. Detection and Hunting
7. Recommendations
8. References

1. Executive Summary

CVE-2026-41108 is a high-severity local privilege-escalation vulnerability in Microsoft Windows DNS / DNS Client components. Microsoft, the CVE record, and NVD align that the issue is a heap-based buffer overflow and that successful exploitation can let a low-privilege authorized attacker obtain `SYSTEM` privileges without user interaction.

The most important operational nuance is exploitation complexity. Microsoft explicitly states that successful exploitation requires winning a race condition, which is why the CVSS v3.1 vector carries `AC:H` despite the impact reaching high confidentiality, integrity, and availability outcomes. This is not a remote unauthenticated wormable issue, but it is still operationally important because it can convert an initial foothold on a Windows endpoint or server into full local compromise.

The affected estate is broad. Reviewed Microsoft records show exposure across Windows 10 1607, 1809, 21H2, and 22H2; Windows 11 23H2, 24H2, 25H2, and 26H1; and Windows Server 2012, 2012 R2, 2016, 2019, 2022, and 2025, including Server Core variants where listed. No reviewed source confirmed in-the-wild exploitation or KEV inclusion at assessment time, but the breadth of impacted Windows platforms and the possibility of `SYSTEM` privilege gain make patching and post-compromise hunting high-priority defensive actions.

2. Intelligence Requirement

This review addresses the following intelligence requirement: what is `CVE-2026-41108`, which Windows platforms are exposed, what does the available public record say about exploitation status and attacker requirements, and what should defenders do immediately to reduce risk?

The client-relevant analytic questions were:

Question	Assessment
What is the vulnerability?	A heap-based buffer overflow in Microsoft Windows DNS that allows local elevation of privilege.
What access does an attacker need?	Low privileges on the local system; Microsoft describes the attacker as authorized.
What is the exploitation constraint?	Microsoft says exploitation requires winning a race condition, increasing complexity but not reducing impact once successful.
What privileges can be gained?	`SYSTEM`, according to Microsoft's FAQ in the June 2026 CVRF release.
Is there confirmed public exploitation?	No confirmed in-the-wild exploitation was found in reviewed sources as of 2026-06-09.
What matters most to defenders?	Patch vulnerable Windows builds, prioritize systems where low-privilege code execution is plausible, and hunt for post-exploitation artifacts on hosts not yet patched.

3. Source Review and Confidence

Source	Contribution	Confidence
Microsoft Security Update Guide entry	Canonical Microsoft description and primary advisory URL for the CVE.	High
Microsoft June 2026 CVRF document	Adds Microsoft FAQ detail that exploitation requires winning a race condition and that successful abuse yields `SYSTEM`; also provides the remediation	High

	KB and fixed-build matrix.	
CVE Program CNA record	Confirms publication timing, `CWE-122`, CVSS v3.1 vectoring, and version-range statements for affected Windows families.	High
NVD JSON 2.0 / detail page	Corroborates Microsoft severity, vector, weakness mapping, and local attack semantics in a normalized public record.	High
Zero Day Initiative June 2026 Patch Tuesday review	Corroborates that the issue was presented publicly as an Important Windows DNS Client EoP with CVSS 7.0 and no public exploitation / disclosure flags in that review table.	Medium
CISA KEV JSON feed	Negative evidence check only: `CVE-2026-41108` was not present in the reviewed KEV feed snapshot dated 2026-06-09.	Medium

Confidence is high on the vulnerability's existence, severity, affected product families, and remediation path because those details are directly supported by Microsoft, the CNA record, and NVD. Confidence is lower on root-cause internals, exploit reliability, and pre-exploitation telemetry because reviewed public sources do not disclose a proof of concept, detailed exploitation procedure, or a stable crash signature beyond the race-condition requirement. Detection guidance in this report therefore emphasizes patch verification, host exposure reduction, and post-compromise hunting rather than claiming a highly specific exploit fingerprint.

4. Key Findings

Core vulnerability metadata

Field	Value
CVE	`CVE-2026-41108`
Vulnerability name	`Windows DNS Client Elevation of Privilege Vulnerability`
Product / component	Microsoft Windows DNS / DNS Client components as described by Microsoft public records
Weakness	`CWE-122` Heap-based Buffer Overflow
Severity	`7.0 / HIGH` (CVSS v3.1)
CVSS v3.1 vector	`AV:L/AC:H/PR:L/UI:N/S:U/C:H/I:H/A:H`
Attack vector	Local
Privileges required	Low
User interaction	None
Exploitation complexity note	Microsoft states successful exploitation requires winning a race condition
Privilege gain on success	`SYSTEM`
Publication date	`2026-06-09`

Customer action required	Yes
Exploitation status at review time	No reviewed authoritative source confirmed in-the-wild exploitation or KEV inclusion

Affected version and patch matrix

Platform family	Vulnerable before	Microsoft remediation
Windows 10 1607 / Windows Server 2016	`10.0.14393.9234`	`KB5094122`
Windows 10 1809 / Windows Server 2019	`10.0.17763.8880`	`KB5094123`
Windows 10 21H2	`10.0.19044.7417`	`KB5094127`
Windows 10 22H2	`10.0.19045.7417`	`KB5094127`
Windows 11 23H2	`10.0.22631.7219`	`KB5093998`
Windows 11 24H2	`10.0.26100.8655`	`KB5094126`
Windows 11 25H2	`10.0.26200.8655`	`KB5094126`
Windows 11 26H1	`10.0.28000.2269`	`KB5095051`
Windows Server 2012	`6.2.9200.26132`	`KB5094042`
Windows Server 2012 R2	`6.3.9600.23228`	`KB5094041`
Windows Server 2022	`10.0.20348.5256`	`KB5094128`
Windows Server 2025	`10.0.26100.32995`	`KB5094125`

Microsoft's CVE record and June 2026 CVRF also list Server Core variants for the affected server platforms. Organizations should treat those variants as in scope even where only minimal GUI components are installed.

Analyst findings

- The issue is best understood as a post-foothold privilege-escalation risk, not an initial-access vulnerability. A threat actor already needs code execution or another authorized low-privilege position on the target host.
- Despite local-only reachability, the business impact can be severe because successful exploitation yields `SYSTEM`, enabling credential theft, security-tool impairment, persistence installation, and lateral-movement preparation.
- The race-condition requirement likely reduces exploit reliability and noiseless mass abuse, but it does not materially reduce urgency for environments where untrusted code often lands on endpoints or shared Windows servers.
- The broad Windows product coverage means patch verification should be inventory-driven rather than limited to a single OS branch.
- No public IOC set, exploit sample, or named threat-actor reporting was identified during this review. Defenders should avoid overstating active exploitation, while still treating unpatched hosts as meaningful privilege-escalation opportunities.

5. Threat Context

The most realistic attack paths for `CVE-2026-41108` begin after another control has already failed. Examples include commodity malware executing in a user session, a developer or administrator opening an untrusted payload, a malicious insider with low-privilege access, or a threat actor landing on a Windows server through credential misuse and then attempting to climb to `SYSTEM`.

From a threat-model perspective, the vulnerability strengthens common adversary chains rather than creating a brand-new remote attack surface. Once a low-privilege process is running locally, an attacker can attempt to exploit the DNS client flaw

to cross the privilege boundary. If successful, likely follow-on behavior includes credential access, service tampering, security-tool evasion, scheduled-task or service-based persistence, and preparation for lateral movement.

No reviewed authoritative source tied the CVE to a named campaign, ransomware family, or KEV listing as of 2026-06-09. The Zero Day Initiative June 2026 review categorized the issue as an Important Windows DNS Client EoP with CVSS 7.0 and marked it as neither publicly exploited nor publicly disclosed in that review table. CISA's reviewed KEV JSON snapshot for the same date did not include `CVE-2026-41108`. That absence should be treated as a time-bounded observation, not a guarantee against future weaponization.

The strongest ATT&CK-aligned mappings supported by the public record are:

Tactic	Technique	Relevance
Privilege Escalation	`T1068` Exploitation for Privilege Escalation	Direct fit: the vulnerability allows a low-privilege local attacker to obtain `SYSTEM`.
Defense Evasion / Credential Access / Persistence (follow-on)	Not assigned with high confidence in the vulnerability record itself	Follow-on behaviors are plausible after successful exploitation, but reviewed public sources do not justify attributing a narrower exploit-specific ATT&CK technique beyond `T1068`.

Higher-risk exposure patterns include developer workstations, jump hosts, VDI pools, shared Windows application servers, terminal servers, and any environment where low-privilege code execution is a realistic daily event. Lower-risk environments are those already patched to the fixed builds above and those with strong application-control policies that materially reduce arbitrary local code execution opportunities.

6. Detection and Hunting

Because the reviewed public record does not expose a detailed exploit chain or stable exploit-specific telemetry fingerprint, the most defensible detection strategy is layered:

- identify vulnerable Windows builds
- watch for suspicious crash or fault activity around DNS-related service components where available
- hunt for abnormal child-process or persistence behavior that would indicate a successful transition to `SYSTEM`
- prioritize retrospective review on systems that remained unpatched after the June 2026 release

Detection logic summary

Signal	Telemetry Source	Analytic Goal
Hosts still below the Microsoft fixed build numbers in the patch matrix	Asset inventory / EDR device inventory / Windows update telemetry	Identify exposure and remediation gaps
Windows Error Reporting or application-fault events involving `svchost.exe` instances associated with DNS Client activity or DNS-related modules such as `dnsapi.dll`	Windows Event Logs / EDR device events	Surface possible failed exploitation attempts or crash-prone testing activity
Unusual child processes launched as `SYSTEM` from service-host contexts or shortly after suspicious low-privilege execution on the same host	EDR process telemetry / Security Event 4688 / Sysmon Event ID 1	Identify likely successful post-exploitation activity
Sudden creation of scheduled tasks, services, local administrators, or credential-dumping tools after a suspicious local	EDR process, registry, and service telemetry	Detect follow-on actions after privilege escalation

execution chain		
Concentrated post-patch exceptions on specific Windows branches	Vulnerability management and incident tracking	Prioritize systems that may have been targeted before remediation

Analyst caveat: the public sources reviewed here do not prove that every exploitation attempt will crash the DNS client path or surface `dnsapi.dll` directly in logs. Those signals are best treated as useful triage pivots rather than deterministic exploit signatures.

6.2 Example Sigma Logic

```

title: Possible Windows DNS Client EoP Follow-On via Unexpected SYSTEM Process Spawn
id: 2b9fe6cf-a5cc-4c3a-9c7d-41108dns-eop
status: experimental
description: Hunts for unusual SYSTEM-level child processes spawned from svchost.exe service-host contexts on Windows systems that may merit review during CVE-2026-41108 investigations.
logsource:
  product: windows
  category: process_creation
detection:
  selection_parent:
    ParentImage|endswith: '\\svchost.exe'
  selection_user:
    User|contains: 'SYSTEM'
  suspicious_child:
    Image|endswith:
      - '\\cmd.exe'
      - '\\powershell.exe'
      - '\\pwsh.exe'
      - '\\rundll32.exe'
      - '\\regsvr32.exe'
      - '\\mshta.exe'
  condition: selection_parent and selection_user and suspicious_child
falsepositives:
  - legitimate administrative tooling launched by trusted service workflows
level: medium

```

6.3 Example Hunt Queries

Exposure inventory query:

```

DeviceInfo
| summarize arg_max(Timestamp, *) by DeviceId
| project DeviceName, OSPlatform, OSVersion, OSBuild, OSDistribution, Timestamp
| order by OSBuild asc

```

Suspicious SYSTEM child-process query:

```

DeviceProcessEvents
| where Timestamp > ago(30d)
| where InitiatingProcessFileName =~ "svchost.exe"
| where AccountName =~ "SYSTEM"
| where FileName in~ ("cmd.exe", "powershell.exe", "pwsh.exe", "rundll32.exe", "regsvr32.exe", "mshta.exe")
| project Timestamp, DeviceName, FileName, ProcessCommandLine, InitiatingProcessCommandLine, AccountName, SHA1
| order by Timestamp desc

```

Crash-telemetry triage query:

```

DeviceEvents
| where Timestamp > ago(30d)
| where ActionType has_any ("Crash", "AppCrash", "Fault", "Wer") or AdditionalFields has_any ("dnsapi.dll", "svchost.exe", "Dnscache")
| project Timestamp, DeviceName, ActionType, FileName, FolderPath, AdditionalFields
| order by Timestamp desc

```

Suggested hunt questions

- Which endpoints and servers remained below the fixed build numbers after 2026-06-09?
- On those hosts, do process trees show suspicious user-context activity shortly before unusual `SYSTEM`-level child processes or persistence changes?
- Are there Windows Error Reporting or fault events for DNS-related service paths that cluster around suspicious execution windows?
- Did any unpatched or late-patched servers later exhibit credential-dumping, admin-group modification, scheduled-task creation, or service-install behavior?
- Are there exceptions concentrated on shared Windows servers, jump hosts, or developer workstations where attackers are more likely to already possess low privileges?

7. Recommendations

Priority	Owner	Action
Critical	Windows Platform / Infrastructure	Deploy the June 2026 Microsoft security updates for all affected Windows client and server branches, including Server Core variants where listed.
Critical	Vulnerability Management	Verify remediation by build number or KB rather than assuming fully patched status from generic maintenance reporting.
High	SOC / Detection Engineering	Create exposure dashboards and hunt playbooks keyed to the fixed-build matrix for `CVE-2026-41108`.
High	SOC / Incident Response	On any host that remained unpatched after 2026-06-09 and shows suspicious local execution, review for `SYSTEM`-level follow-on behavior, credential theft, persistence, and service tampering.
High	Endpoint Security	Strengthen application control, macro/script restrictions, and endpoint prevention controls that reduce the chance of low-privilege code execution in the first place.
Medium	Server / Identity Owners	Prioritize jump hosts, administrative workstations, shared Windows servers, and other systems where a low-privilege foothold could quickly become a domain-impacting problem after local escalation.
Medium	Threat Intelligence	Recheck KEV, vendor advisories, and public exploit reporting over the following patch cycles in case exploitation status changes after initial publication.

Additional analyst guidance

- Treat this issue as high-priority even without confirmed active exploitation because the path to `SYSTEM` materially increases the value of otherwise lower-severity footholds.
- Do not overstate available detection precision; public reporting currently supports strong exposure management and post-compromise hunting more than a precise exploit signature.

- If compensating controls delay patching, document the exception, isolate the host where possible, and increase EDR review depth on that system until remediation is complete.

8. References

- Microsoft Security Update Guide: <https://msrc.microsoft.com/update-guide/vulnerability/CVE-2026-41108>
- Microsoft Security Response Center CVRF, June 2026 Security Updates:
<https://api.msrc.microsoft.com/cvrf/v3.0/cvrf/2026-Jun>
- CVE Program CNA API record: <https://cveawg.mitre.org/api/cve/CVE-2026-41108>
- NVD detail page: <https://nvd.nist.gov/vuln/detail/CVE-2026-41108>
- NVD JSON 2.0 API query: <https://services.nvd.nist.gov/rest/json/cves/2.0?cveId=CVE-2026-41108>
- Zero Day Initiative, The June 2026 Security Update Review: <https://www.zerodayinitiative.com/blog/2026/6/9/the-june-2026-security-update-review>
- CISA Known Exploited Vulnerabilities JSON feed:
https://www.cisa.gov/sites/default/files/feeds/known_exploited_vulnerabilities.json